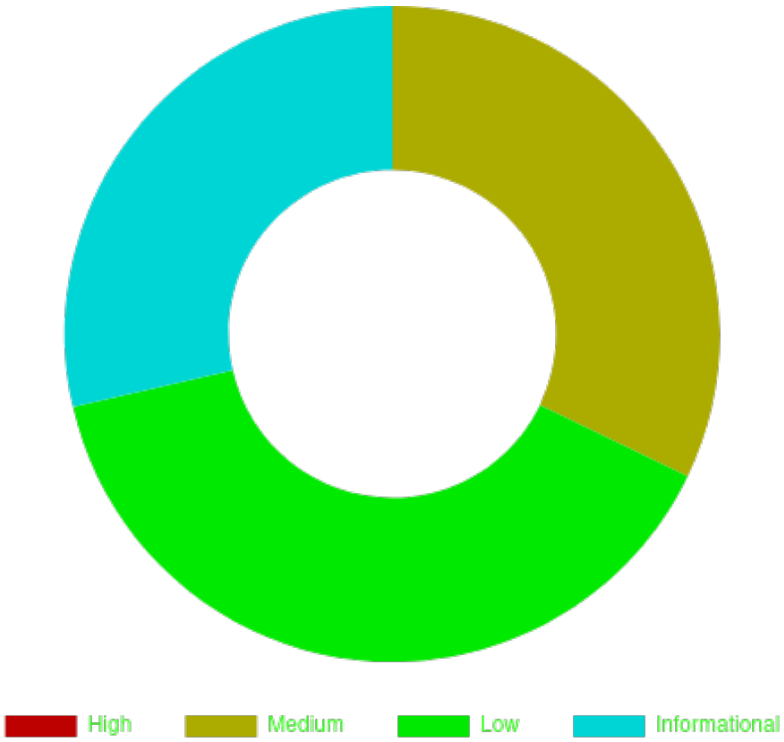
DVWA_ZAP_Analysis

Generated on Fri, 17 Apr 2026 12:48:28

ZAP Version: 2.17.0

ZAP by Checkmarx



Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	9
Low	11
Informational	8

Insights

Level	Reason	Site	Description	Statistic
Low	Warning		ZAP errors logged - see the zap.log file for details	4
Low	Warning		ZAP warnings logged - see the zap.log file for details	14
Info	Informational		Percentage of network failures	1 %
Info	Informational	http://10.128.162.166	Percentage of responses with status code 2xx	53 %
Info	Informational	http://10.128.162.166	Percentage of responses with status code 3xx	6 %
Info	Informational	http://10.128.162.166	Percentage of responses with status code 4xx	39 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type application/javascript	1 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type application/pdf	1 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type application/xml	1 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type image/png	1 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type image/vnd.microsoft.icon	1 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type text/css	1 %

Info	Informational	http://10.128.162.166	Percentage of endpoints with content type text/html	75 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with content type text/plain	19 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with method GET	97 %
Info	Informational	http://10.128.162.166	Percentage of endpoints with method POST	2 %
Info	Informational	http://10.128.162.166	Count of total endpoints	551
Info	Informational	http://10.128.162.166	Percentage of slow responses	34 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with content type application/javascript	13 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with content type image/png	13 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with content type image/vnd.microsoft.icon	4 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with content type text/css	9 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with content type text/html	54 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with content type text/plain	4 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with method GET	95 %
Info	Informational	http://10.130.152.1	Percentage of endpoints with method POST	4 %

Info	Informational	http://10.130.152.1	Count of total endpoints	22
Info	Informational	http://www.dvwa.co.uk	Percentage of responses with status code 2xx	63 %
Info	Informational	http://www.dvwa.co.uk	Percentage of responses with status code 4xx	36 %
Info	Informational	http://www.dvwa.co.uk	Percentage of slow responses	60 %
Info	Informational	https://10.128.162.166	Percentage of endpoints with method GET	100 %
Info	Informational	https://10.128.162.166	Count of total endpoints	1
Info	Informational	https://10.130.152.1	Percentage of endpoints with method GET	100 %
Info	Informational	https://10.130.152.1	Count of total endpoints	1
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of responses with status code 2xx	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with content type application/octet-stream	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of endpoints with method GET	100 %
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Count of total endpoints	1
Info	Informational	https://firefox-settings-attachments.cdn.mozilla.net	Percentage of slow responses	100 %
Info	Informational	https://www.dvwa.co.uk	Percentage of responses with status code 4xx	100 %

Info	Informational	https://www.dvwa.co.uk	Percentage of slow responses	100 %

Alerts

Name	Risk Level	Number of Instances
Absence of Anti-CSRF Tokens	**Medium**	5
CSP: Failure to Define Directive with No Fallback	**Medium**	2
CSP: Wildcard Directive	**Medium**	2
CSP: style-src unsafe-inline	**Medium**	2
Content Security Policy (CSP) Header Not Set	**Medium**	Systemic
HTTP Only Site	**Medium**	2
Hidden File Found	**Medium**	1
Missing Anti-clickjacking Header	**Medium**	Systemic
Sub Resource Integrity Attribute Missing	**Medium**	1
Cookie No HttpOnly Flag	**Low**	1
Cookie without SameSite Attribute	**Low**	2
Cross-Domain JavaScript Source File Inclusion	**Low**	1
In Page Banner Information Leak	**Low**	3
Information Disclosure - Debug Error Messages	**Low**	2
Private IP Disclosure	**Low**	1
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	**Low**	Systemic
Server Leaks Version Information via "Server" HTTP Response Header Field	**Low**	Systemic
Strict-Transport-Security Header Not Set	**Low**	1
Timestamp Disclosure - Unix	**Low**	Systemic

X-Content-Type-Options Header Missing	**Low**	Systemic
Authentication Request Identified	**Informational**	4
Information Disclosure - Sensitive Information in URL	**Informational**	5
Information Disclosure - Suspicious Comments	**Informational**	2
Modern Web Application	**Informational**	1
Retrieved from Cache	**Informational**	1
Session Management Response Identified	**Informational**	2
User Agent Fuzzer	**Informational**	Systemic
User Controllable HTML Element Attribute (Potential XSS)	**Informational**	2

Passing Rules

Name	Rule Type	Threshold	Strength
Directory Browsing	Active	MEDIUM	MEDIUM
Path Traversal	Active	MEDIUM	MEDIUM
Remote File Inclusion	Active	MEDIUM	MEDIUM
XSLT Injection	Active	MEDIUM	MEDIUM
Server Side Code Injection	Active	MEDIUM	MEDIUM
XPath Injection	Active	MEDIUM	MEDIUM
Remote OS Command Injection	Active	MEDIUM	MEDIUM
XML External Entity Attack	Active	MEDIUM	MEDIUM
Generic Padding Oracle	Active	MEDIUM	MEDIUM
SOAP Action Spoofing	Active	MEDIUM	MEDIUM
SOAP XML Injection	Active	MEDIUM	MEDIUM
Heartbleed OpenSSL Vulnerability	Active	MEDIUM	MEDIUM

Buffer Overflow	Active	MEDIUM	MEDIUM
Source Code Disclosure - CVE-2012-1823	Active	MEDIUM	MEDIUM
Format String Error	Active	MEDIUM	MEDIUM
Server Side Template Injection	Active	MEDIUM	MEDIUM
Remote Code Execution - CVE-2012-1823	Active	MEDIUM	MEDIUM
Cloud Metadata Potentially Exposed	Active	MEDIUM	MEDIUM
External Redirect	Active	MEDIUM	MEDIUM
Remote OS Command Injection (Time Based)	Active	MEDIUM	MEDIUM
Server Side Template Injection (Blind)	Active	MEDIUM	MEDIUM
Source Code Disclosure - /WEB-INF Folder	Active	MEDIUM	MEDIUM
HTTPS Content Available via HTTP	Active	MEDIUM	MEDIUM
Remote Code Execution - Shell Shock	Active	MEDIUM	MEDIUM
CRLF Injection	Active	MEDIUM	MEDIUM
Parameter Tampering	Active	MEDIUM	MEDIUM
Server Side Include	Active	MEDIUM	MEDIUM
GET for POST	Active	MEDIUM	MEDIUM
Cross Site Scripting (Reflected)	Active	MEDIUM	MEDIUM
Cross Site Scripting (Persistent)	Active	MEDIUM	MEDIUM
Script Active Scan Rules	Active	MEDIUM	MEDIUM
Cross Site Scripting (Persistent) - Prime	Active	MEDIUM	MEDIUM
Cross Site Scripting (Persistent) - Spider	Active	MEDIUM	MEDIUM
SQL Injection	Active	MEDIUM	MEDIUM
SQL Injection - MySQL (Time Based)	Active	MEDIUM	MEDIUM
SQL Injection - Hypersonic SQL (Time Based)	Active	MEDIUM	MEDIUM
SQL Injection - Oracle (Time Based)	Active	MEDIUM	MEDIUM

SQL Injection - PostgreSQL (Time Based)	Active	MEDIUM	MEDIUM
SQL Injection - SQLite (Time Based)	Active	MEDIUM	MEDIUM
Cross Site Scripting (DOM Based)	Active	MEDIUM	MEDIUM
SQL Injection - MsSQL (Time Based)	Active	MEDIUM	MEDIUM
ELMAH Information Leak	Active	MEDIUM	MEDIUM
Trace.axd Information Leak	Active	MEDIUM	MEDIUM
.htaccess Information Leak	Active	MEDIUM	MEDIUM
.env Information Leak	Active	MEDIUM	MEDIUM
Spring Actuator Information Leak	Active	MEDIUM	MEDIUM
Log4Shell	Active	MEDIUM	MEDIUM
Exponential Entity Expansion (Billion Laughs Attack)	Active	MEDIUM	MEDIUM
Spring4Shell	Active	MEDIUM	MEDIUM
Remote Code Execution (React2Shell)	Active	MEDIUM	MEDIUM
Verification Request Identified	Passive	MEDIUM	-
Session ID in URL Rewrite	Passive	MEDIUM	-
Script Served From Malicious Domain (polyfill)	Passive	MEDIUM	-
ZAP is Out of Date	Passive	MEDIUM	-
Insecure JSF ViewState	Passive	MEDIUM	-
Java Serialization Object	Passive	MEDIUM	-
Vulnerable JS Library (Powered by Retire.js)	Passive	MEDIUM	-
Charset Mismatch	Passive	MEDIUM	-
Cookie Without Secure Flag	Passive	MEDIUM	-
Re-examine Cache-control Directives	Passive	MEDIUM	-
Content-Type Header Missing	Passive	MEDIUM	-
Application Error Disclosure	Passive	MEDIUM	-

Information Disclosure - Sensitive Information in HTTP Referrer Header	Passive	MEDIUM	-
Off-site Redirect	Passive	MEDIUM	-
Cookie Poisoning	Passive	MEDIUM	-
User Controllable Charset	Passive	MEDIUM	-
WSDL File Detection	Passive	MEDIUM	-
Loosely Scoped Cookie	Passive	MEDIUM	-
Viewstate	Passive	MEDIUM	-
Directory Browsing	Passive	MEDIUM	-
Heartbleed OpenSSL Vulnerability (Indicative)	Passive	MEDIUM	-
X-Backend-Server Header Information Leak	Passive	MEDIUM	-
Secure Pages Include Mixed Content	Passive	MEDIUM	-
HTTP to HTTPS Insecure Transition in Form Post	Passive	MEDIUM	-
HTTPS to HTTP Insecure Transition in Form Post	Passive	MEDIUM	-
User Controllable JavaScript Event (XSS)	Passive	MEDIUM	-
Big Redirect Detected (Potential Sensitive Information Leak)	Passive	MEDIUM	-
X-ChromeLogger-Data (XCOLD) Header Information Leak	Passive	MEDIUM	-
X-Debug-Token Information Leak	Passive	MEDIUM	-
Username Hash Found	Passive	MEDIUM	-
X-AspNet-Version Response Header	Passive	MEDIUM	-
PII Disclosure	Passive	MEDIUM	-
Script Passive Scan Rules	Passive	MEDIUM	-
Stats Passive Scan Rule	Passive	MEDIUM	-
Hash Disclosure	Passive	MEDIUM	-
Cross-Domain Misconfiguration	Passive	MEDIUM	-

Weak Authentication Method	Passive	MEDIUM	-
Reverse Tabnabbing	Passive	MEDIUM	-

Sites

https://10.130.152.1

HTTP Response Code	Number of Responses

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values

http://10.130.152.1

HTTP Response Code	Number of Responses

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values

https://firefox-settings-attachments.cdn.mozilla.net

HTTP Response Code	Number of Responses
200 OK	1

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values

https://10.128.162.166

HTTP Response Code	Number of Responses

No Authentication Statistics Found

Parameter Name	Type	Flags	Times Used	# Values

http://10.128.162.166

HTTP Response Code	Number of Responses
403 Forbidden	8
404 Not Found	368
200 OK	511
302 Found	60

Authentication Statistics	Number of Responses
stats.auth.sessiontoken.security	6
stats.auth.sessiontoken.PHPSESSID	8

Parameter Name	Type	Flags	Times Used	# Values

Alert Detail

Medium	**Absence of Anti-CSRF Tokens**
Description	No Anti-CSRF tokens were found in a HTML submission form. A cross-site request forgery is an attack that involves forcing a victim to send an HTTP request to a target destination without their knowledge or intent in order to perform an action as the victim. The underlying cause is application functionality using predictable URL/form actions in a repeatable way. The nature of the attack is that

CSRF exploits the trust that a web site has for a user. By contrast, cross-site scripting (XSS) exploits the trust that a user has for a web site. Like XSS, CSRF attacks are not necessarily cross-site, but they can be. Cross-site request forgery is also known as CSRF, XSRF, one-click attack, session riding, confused deputy, and sea surf.

CSRF attacks are effective in a number of situations, including:

* The victim has an active session on the target site.

* The victim is authenticated via HTTP auth on the target site.

* The victim is on the same local network as the target site.

CSRF has primarily been used to perform an action against a target site using the victim's privileges, but recent techniques have been discovered to disclose information by gaining access to the response. The risk of information disclosure is dramatically increased when the target site is vulnerable to XSS, because XSS can be used as a platform for CSRF, allowing the attack to operate within the bounds of the same-origin policy.

URL	http://10.128.162.166/vulnerabilities/csp/
Node Name	http://10.128.162.166/vulnerabilities/csp/
Method	GET
Parameter	
Attack	
Evidence	<form name="csp" method="POST">
Show/hideRe	

quest and Response

Request Header-size: 458 bytes.

Request Body-size: 0 bytes.

Response Header-size: 492 bytes.

Response Body - size: 4,223 bytes.

URL http://10.128.162.166/vulnerabilities/javascript/

Node Name http://10.128.162.166/vulnerabilities/javascript/

Method GET

Parameter

Attack

Evidence <form name="low_js" method="post">

Show/hide Request and Re

sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
46
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
3
by
te
s.

Re
sp
on
se
Bo

dy
-
si
ze
:
8,
38
1
by
te
s.

URL http://10.128.162.166/vulnerabilities/weak_id/

No
de
Na
me http://10.128.162.166/vulnerabilities/weak_id/

Me
th
od GET

Pa
ra
me
te
r

At
ta
ck

Ev
id
en
ce <form method="post">

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
35
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
30
8
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze

:
3,
532
bytes.

URL http://10.128.162.166/vulnerabilities/xss_s/

Node Name http://10.128.162.166/vulnerabilities/xss_s/

Method GET

Parameter

Attack

Evidence <form method="post" name="guestform" ">

Show/hide Request and Response

Request He

ad
er
-
si
ze
:
46
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
4,
99
2
by
te

s.

URL http://10.128.162.166/vulnerabilities/xss_s/

Node Name http://10.128.162.166/vulnerabilities/xss_s/ ()(btnSign,mtxMessage,txtName)

Method POST

Parameter

Attack

Evidence <form method="post" name="guestform" ">

Show/hide Request and Response

Request Header-size:

561 bytes.

Request Body-size: 59 bytes.

Response Header-size: 364 bytes.

Response Body-size: 5,069 bytes.

Instances 5

	Phase: Architecture and Design Use a vetted library or framework that does not allow this weakness to occur or provides constructs that make this weakness easier to avoid. For example, use anti-CSRF packages such as the OWASP CSRFGuard. Phase: Implementation Ensure that your application is free of cross-site scripting issues, because most CSRF defenses can be bypassed using attacker-controlled script. Phase: Architecture and Design Generate a unique nonce for each form, place the nonce into the form, and verify the nonce upon receipt of the form. Be sure that the nonce is not predictable (CWE-330).
Solution	Note that this can be bypassed using XSS. Identify especially dangerous operations. When the user performs a dangerous operation, send a separate confirmation request to ensure that the user intended to perform that operation. Note that this can be bypassed using XSS. Use the ESAPI Session Management control. This control includes a component for CSRF. Do not use the GET method for any request that triggers a state change. Phase: Implementation Check the HTTP Referer header to see if the request originated from an expected page. This could break legitimate functionality, because users or proxies may have disabled sending the Referer for privacy reasons.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html https://cwe.mitre.org/data/definitions/352.html
Tags	OWASP_2021_A01 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC WSTG-v42-SESS-05 OWASP_2017_A05 CWE-352 POLICY_DEV_STD =
CWE Id	352
WASC Id	9

Plugin Id	10202

Medium	**CSP: Failure to Define Directive with No Fallback**
Description	The Content Security Policy fails to define one of the directives that has no fallback. Missing/excluding them is the same as allowing anything.
URL	http://10.128.162.166/vulnerabilities/csp/
Node Name	http://10.128.162.166/vulnerabilities/csp/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl.google-analytics.com ;
Show/hide Request and Response	

Request Header-size: 458 bytes.

Request Body-size: 0 bytes.

Response Header-size: 492 bytes.

Response Body-size

: 4, 223 bytes.

URL http://10.128.162.166/vulnerabilities/csp/

Node Name http://10.128.162.166/vulnerabilities/csp/

Method GET

Parameter Content-Security-Policy

Attack

Evidence script-src 'self';

Show/hide Request and Response

Request He

ad
er
-
si
ze
:
34
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
35
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
4,
37
7
by
te

s.

Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC CWE-693 OWASP_2017_A06 POLICY_DEV_STD =
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	**CSP: Wildcard Directive**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://10.128.162.166/vulnerabilities/csp/
Node Name	http://10.128.162.166/vulnerabilities/csp/
Method	GET

Parameter: Content-Security-Policy

Attack:

Evidence: script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl.google-analytics.com ;

Show/hide Request and Response

Request Header-size: 458 bytes.

Request Body-si

ze: 0 bytes.

ResponseHeader-size: 492 bytes.

ResponseBody-size: 4,223 bytes.

URL http://10.128.162.166/vulnerabilities/csp/

NodeName http://10.128.162.166/vulnerabilities/csp/

Method GET

Parameter Content-Security-Policy

r

Attack

Evidence script-src 'self';

Show/hideRequestandResponse

RequestHeader-size:349bytes.

RequestBody-size:0byte

s.

Response Header-size: 353 bytes.

Response Body-size: 4,377 bytes.

Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC CWE-693 OWASP_2017_A06 POLICY_DEV_STD =
CWE Id	693

WASC Id	15
Plugin Id	10055

Medium	**CSP: style-src unsafe-inline**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://10.128.162.166/vulnerabilities/csp/
Node Name	http://10.128.162.166/vulnerabilities/csp/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	script-src 'self' https://pastebin.com example.com code.jquery.com https://ssl.google-analytics.com ;
Show/hideRequ	

est
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
45
8
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
49
2
by
te
s.

Response Body - size: 4,223 bytes.	
URL	http://10.128.162.166/vulnerabilities/csp/
Node Name	http://10.128.162.166/vulnerabilities/csp/
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	script-src 'self';
Show/hide Request and Re	

sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
34
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
35
3
by
te
s.

Re
sp
on
se
Bo

dy
-
si
ze
:
4,
37
7
by
te
s.

Instances	2
Solution	Ensure that your web server, application server, load balancer, etc. is properly configured to set the Content-Security-Policy header.
Reference	https://www.w3.org/TR/CSP/ https://caniuse.com/#search=content+security+policy https://content-security-policy.com/ https://github.com/HtmlUnit/htmlunit-csp https://web.dev/articles/csp#resource-options
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC CWE-693 OWASP_2017_A06 POLICY_DEV_STD =
CWE Id	693
WASC Id	15
Plugin Id	10055

Medium	**Content Security Policy (CSP) Header Not Set**
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://10.128.162.166/

Node Name	http://10.128.162.166/
Method	GET
Parameter	
Attack	
Evidence	
Show/hide Request and Response	
Request Header-size: 229 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 308 bytes.

Response Body-size: 1,523 bytes.

URL http://10.128.162.166/login.php

Node Name	http://10.128.162.166/login.php
Method	GET
Parameter	
Attack	
Evidence	
Show/hide Request and Response	
Request Header-size: 338 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 308 bytes.

Response Body-size: 1,523 bytes.

URL http://10.128.162.166/security.php

Node Name	http://10.128.162.166/security.php
Method	GET
Parameter	
Attack	
Evidence	
Show/hide Request and Response	
Request Header-size: 440 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 364 bytes.

Response Body-size: 5,389 bytes.

URL http://10.128.162.166/sitemap.xml

Node Name	http://10.128.162.166/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Show/hide Request and Response	
Request Header-size: 240 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 160 bytes.

Response Body-size: 288 bytes.

URL http://10.128.162.166/vulnerabilities/sqli/

Node Name http://10.128.162.166/vulnerabilities/sqli/

Method GET

Parameter

Attack

Evidence

Show/hide Request and Response

Request Header-size: 449 bytes.

Reques

t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
4,
47
9
by
te
s.

Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy

	https://content-security-policy.com/
Tags	CWE-693 OWASP_2021_A05 OWASP_2017_A06 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**HTTP Only Site**
Description	The site is only served under HTTP and not HTTPS.
URL	http://10.128.162.166/
Node Name	https://10.128.162.166/
Method	GET
Parameter	
Attack	
Evidence	
Show/hi	

de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
23
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Response Header-size: 14 bytes.

Response Body-size: 0 bytes.

URL http://10.130.152.1/

Node Name https://10.130.152.1/

Method GET

Parameter

Attack

Evidence

ce

Show/hide Request and Response

Request Header-size: 226 bytes.

Request Body-size: 0 bytes.

Response Header-

size: 14 bytes.

Response Body - size: 0 bytes.

Instances	2
Solution	Configure your web or application server to use SSL (https).
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Transport_Layer_Protection_Cheat_Sheet.html https://letsencrypt.org/
Tags	OWASP_2021_A05 OWASP_2017_A06 WSTG-v42-CRYP-03 POLICY_QA_FULL = POLICY_PENTEST = CWE-311
CWE Id	311
WASC Id	4
Plugin Id	10106

Medium	**Hidden File Found**
Description	A sensitive file was identified as accessible or available. This may leak administrative, configuration, or credential information which can be leveraged by a malicious individual to further attack the system or conduct social engineering efforts.

URL	http://10.128.162.166/phpinfo.php
Node Name	http://10.128.162.166/phpinfo.php
Method	GET
Parameter	
Attack	
Evidence	HTTP/1.1 200 OK
Show/hide Request and Response	
Request Header-size: 286	

bytes.

Request Body-size: 0 bytes.

Response Header-size: 443 bytes.

Response Body-size: 76,630 bytes.

Instances 1

Solution Consider whether or not the component is actually required in production, if it isn't then disable it. If it is then ensure access to it requires appropriate authentication and authorization, or limit

	exposure to internal systems or specific source IPs, etc.
Reference	https://blog.hboeck.de/archives/892-Introducing-Snallygaster-a-Tool-to-Scan-for-Secrets-on-Web-Servers.html https://www.php.net/manual/en/function.phpinfo.php
Tags	OWASP_2021_A05 OWASP_2017_A06 POLICY_QA_FULL = POLICY_PENTEST = CWE-538 WSTG-v42-CONF-05
CWE Id	538
WASC Id	13
Plugin Id	40035

Medium	**Missing Anti-clickjacking Header**
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	x-frame-options
Attack	

Evidence

Show/hide Request and Response

Request Header-size: 229 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 308 bytes.

Response Body-size: 1,523 bytes.

URL http://10.128.162.166/login.php

Node Name http://10.128.162.166/login.php

Method GET

Parameter x-frame-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 338 bytes.

Request Body-size: 0 bytes.

Response Header-size

: 308 bytes.

Response Body-size: 1,523 bytes.

URL http://10.128.162.166/security.php

Node Name http://10.128.162.166/security.php

Method GET

Parameter x-frame-options

Attack

Evidence

Show/hide

Request and Response

Request Header-size: 440 bytes.

Request Body-size: 0 bytes.

Response Header-size: 364 bytes.

Response Body-size: 5,389 bytes.

URL http://10.128.162.166/vulnerabilities/sqli/

Node Name http://10.128.162.166/vulnerabilities/sqli/

Method GET

Parameter x-frame-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 449 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 363 bytes.

Response Body-size: 4,479 bytes.

URL http://10.128.162.166/vulnerabilities/sqli_blind/

Node Name http://10.128.162.166/vulnerabilities/sqli_blind/

Method GET

Parameter x-frame-options

Attack

Evidence

Show/hideRequestandResponse

RequestHeader-size:464bytes.

RequestBody-size:0bytes.

ResponseHeader-size

: 363 bytes.

Response Body - size: 4,519 bytes.

Instances	Systemic
	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.
Solution	If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = CWE-1021 SYSTEMIC WSTG-v42-CLNT-09 OWASP_2017_A06
CWE Id	1021
WASC Id	15
Plugin Id	10020

Medium **Sub Resource Integrity Attribute Missing**

Description	The integrity attribute is missing on a script or link tag served by an external server. The integrity tag prevents an attacker who have gained access to this server from injecting a malicious content.
URL	http://10.128.162.166/vulnerabilities/captcha/
Node Name	http://10.128.162.166/vulnerabilities/captcha/
Method	GET
Parameter	
Attack	
Evidence	<script src='https://www.google.com/recaptcha/api.js'></script>
Show/hide Request and Response	
Request Header	

-
si
ze
:
35
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
30
8
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
4,
92
7
by
te
s.

Instances	1
Solution	Provide a valid integrity attribute to the tag.
Reference	https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity
Tags	CWE-345 OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2017_A06 POLICY_DEV_STD =
CWE Id	345
WASC Id	15
Plugin Id	90003

Low	**Cookie No HttpOnly Flag**
Description	A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	PHPSESSID

Attack

Evidence Set-Cookie: PHPSESSID

Show/hide Request and Response

Request Header-size: 229 bytes.

Request Body-size: 0 bytes.

Response Header-size: 498 bytes.

Response Body-size: 0 bytes.

Instances	1
Solution	Ensure that the HttpOnly flag is set for all cookies.
Reference	https://owasp.org/www-community/HttpOnly
Tags	CWE-1004 OWASP_2021_A05 POLICY_QA_STD = WSTG-v42-SESS-02 POLICY_PENTEST = SYSTEMIC OWASP_2017_A06 POLICY_DEV_STD =
CWE Id	1004
WASC Id	13
Plugin Id	10010

Low	**Cookie without SameSite Attribute**
Description	A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	PHPSESSID
Attack	
Evidence	Set-Cookie: PHPSESSID
Show/hide Request and Response	
Requ	

es
t
He
ad
er
-
si
ze
:
22
9
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
49
8
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
0
by

tes.	
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	security
Attack	
Evidence	Set-Cookie: security
Show/hide Request and Response	
Request Header-size	

:
229
bytes.

Request Body-size: 0 bytes.

Response Header-size: 498 bytes.

Response Body-size: 0 bytes.

Instances 2

Solution	Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies.
Reference	https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site
Tags	OWASP_2021_A01 POLICY_QA_STD = WSTG-v42-SESS-02 POLICY_PENTEST = SYSTEMIC CWE-1275 OWASP_2017_A05 POLICY_DEV_STD =
CWE Id	1275
WASC Id	13
Plugin Id	10054

Low	**Cross-Domain JavaScript Source File Inclusion**
Description	The page includes one or more script files from a third-party domain.
URL	http://10.128.162.166/vulnerabilities/captcha/
Node Name	http://10.128.162.166/vulnerabilities/captcha/
Method	GET
Parameter	https://www.google.com/recaptcha/api.js
Attack	
Evidence	<script src='https://www.google.com/recaptcha/api.js'></script>

ce

Show/hideRequestandResponse

RequestHeader-size:353bytes.

RequestBody-size:0bytes.

ResponseHeader-

size: 308 bytes.

ResponseBody-size: 4,927 bytes.

Instances	1
Solution	Ensure JavaScript source files are loaded from only trusted sources, and the sources can't be controlled by end users of the application.
Reference	
Tags	OWASP_2021_A08 CWE-829 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC POLICY_DEV_STD =
CWE Id	829
WASC Id	15
Plugin Id	10017

Low	**In Page Banner Information Leak**
Description	The server returned a version banner string in the response content. Such information leaks may allow attackers to further target specific issues impacting the product and version in use.

URL	http://10.128.162.166/DTD/xhtml1-transitional.dtd
Node Name	http://10.128.162.166/DTD/xhtml1-transitional.dtd
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.7
Show/hide Request and Response	
Request Header-size: 367	

by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
16
0
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
30
4
by
te
s.

URL http://10.128.162.166/sitemap.xml

No http://10.128.162.166/sitemap.xml
de
Na

me

Method GET

Parameter

Attack

Evidence Apache/2.4.7

Show/hideRequestandResponse

RequestHeader-size:240bytes.

Request Body-size: 0 bytes.

Response Header-size: 160 bytes.

Response Body-size: 288 bytes.

URL http://10.128.162.166/var/www/html/config/config.inc.php

Node Name http://10.128.162.166/var/www/html/config/config.inc.php

Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.7
Show/hide Request and Response	
Request Header-size: 372 bytes.	
Request	

t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
16
0
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
31
1
by
te
s.

Instances	3
Solution	Configure the server to prevent such information leaks. For example: Under Tomcat this is done via the "server" directive and implementation of custom error pages. Under Apache this is done via the "ServerSignature" and "ServerTokens" directives.
Reference	https://owasp.org/www-project-web-security-testing-guide/v41/4-Web_Application_Security_Testing/08-Testing_for_Error_Handling/

Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2017_A06 WSTG-v42-INFO-02 CWE-497
CWE Id	497
WASC Id	13
Plugin Id	10009

Low	**Information Disclosure - Debug Error Messages**
Description	The response appeared to contain common error messages returned by platforms such as ASP.NET, and Web-servers such as IIS and Apache. You can configure the list of common debug messages.
URL	http://10.128.162.166/instructions.php
Node Name	http://10.128.162.166/instructions.php
Method	GET
Parameter	
Attack	
Evidence	PHP warning
Show/	

hide Request and Response

Request Header-size: 345 bytes.

Request Body-size: 0 bytes.

Response Header-size: 309 by

tes.	
Response Body - size: 15,385 bytes.	
URL	http://10.128.162.166/instructions.php?doc=readme
Node Name	http://10.128.162.166/instructions.php (doc)
Method	GET
Parameter	
Attack	
Evidence	PHP warning
Show/hide Request	

and
Response

Request Header-size: 372 bytes.

Request Body-size: 0 bytes.

Response Header-size: 309 bytes.

Resp

onseBody-size: 14,091 bytes.	
Instances	2
Solution	Disable debugging messages before pushing to production.
Reference	
Tags	OWASP_2021_A01 WSTG-v42-ERRH-01 OWASP_2017_A03 CWE-1295 POLICY_PENTEST =
CWE Id	1295
WASC Id	13
Plugin Id	10023

Low	**Private IP Disclosure**
Description	A private IP (such as 10.x.x.x, 172.x.x.x, 192.168.x.x) or an Amazon EC2 private hostname (for example, ip-10-0-56-78) has been found in the HTTP response body. This information might be helpful for further attacks targeting internal systems.
URL	http://10.128.162.166/phpinfo.php
Node Name	http://10.128.162.166/phpinfo.php
Method	GET

Parameter

Attack

Evidence ip-10-128-162-166

Show/hide Request and Response

Request Header-size: 340 bytes.

Request Body-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
33
2
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
76
,8
23
by
te
s.

Instances	1
Solution	Remove the private IP address from the HTTP response body. For comments, use JSP/ASP/PHP comment instead of HTML/JavaScript comment which can be seen by client browsers.
Reference	https://datatracker.ietf.org/doc/html/rfc1918
Tags	OWASP_2021_A01 OWASP_2017_A03 POLICY_QA_STD = POLICY_PENTEST = CWE-497
CWE Id	497

WASC Id	13
Plugin Id	2

Low	**Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	
Attack	
Evidence	X-Powered-By: PHP/5.5.9-1ubuntu4.26
Show/hideRequestand	

Response

Request Header-size: 229 bytes.

Request Body-size: 0 bytes.

Response Header-size: 308 bytes.

Response

Body-size: 1,523 bytes.

URL http://10.128.162.166/login.php

Node Name http://10.128.162.166/login.php

Method GET

Parameter

Attack

Evidence X-Powered-By: PHP/5.5.9-1ubuntu4.26

Show/hide Request and Response

Request Header-size: 338 bytes.

Request Body-size: 0 bytes.

Response Header-size: 308 bytes.

Response Body-size

:
1,
523
bytes.

URL http://10.128.162.166/security.php

Node Name http://10.128.162.166/security.php

Method GET

Parameter

Attack

Evidence X-Powered-By: PHP/5.5.9-1ubuntu4.26

Show/hide Request and Response

Request He

ad
er
-
si
ze
:
44
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
4
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
5,
38
9
by
te

s.

URL http://10.128.162.166/vulnerabilities/sqli/

Node Name http://10.128.162.166/vulnerabilities/sqli/

Method GET

Parameter

Attack

Evidence X-Powered-By: PHP/5.5.9-1ubuntu4.26

Show/hide Request and Response

Request Header-size:

449 bytes.

Request Body-size: 0 bytes.

Response Header-size: 363 bytes.

Response Body-size: 4,479 bytes.

URL http://10.128.162.166/login.php

Node Name	http://10.128.162.166/login.php () (Login,password,user_token,username)
Method	POST
Parameter	
Attack	
Evidence	X-Powered-By: PHP/5.5.9-1ubuntu4.26
Show/hide Request and Response	
Request Header-size: 417 byte	

s.

Request Body-size: 81 bytes.

Response Header-size: 329 bytes.

Response Body-size: 0 bytes.

Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework

	https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Tags	OWASP_2021_A01 WSTG-v42-INFO-08 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2017_A03 CWE-497
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	**Server Leaks Version Information via "Server" HTTP Response Header Field**
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	
Attack	
Evidence	Apache/2.4.7 (Ubuntu)

Show/hideRequestandResponse

RequestHeader-size:229bytes.

RequestBody-size:0bytes.

ResponseHeader-size

: 308 bytes.

Response Body - size: 1,523 bytes.

URL http://10.128.162.166/dvwa/css/login.css

Node Name http://10.128.162.166/dvwa/css/login.css

Method GET

Parameter

Attack

Evidence Apache/2.4.7 (Ubuntu)

Show/hide

Request and Response

Request Header-size: 356 bytes.

Request Body-size: 0 bytes.

Response Header-size: 250 bytes.

Response Body-size: 842 bytes.

URL http://10.128.162.166/robots.txt

Node Name http://10.128.162.166/robots.txt

Method GET

Parameter

Attack

Evidence

Apache/2.4.7 (Ubuntu)

Show/hide Request and Response

Request Header-size: 239 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 227 bytes.

Response Body-size: 26 bytes.

URL http://10.128.162.166/security.php

Node Name http://10.128.162.166/security.php

Method GET

Parameter

Attack

Evidence Apache/2.4.7 (Ubuntu)

Show/hide Request and Response

Request Header-size: 440 bytes.

Request Body-size: 0 bytes.

Response Header-size

:
364
bytes.

ResponseBody-size:
5,389
bytes.

URL http://10.128.162.166/sitemap.xml

NodeName http://10.128.162.166/sitemap.xml

Method GET

Parameter

Attack

Evidence Apache/2.4.7 (Ubuntu)

Show/hide

Request and Response

Request Header-size: 240 bytes.

Request Body-size: 0 bytes.

Response Header size: 160 bytes.

Response Body size: 288 bytes.

Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
Tags	OWASP_2021_A05 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2017_A06 WSTG-v42-INFO-02 CWE-497
CWE Id	497
WASC Id	13

Plugin Id	10036

Low	**Strict-Transport-Security Header Not Set**
Description	HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
URL	https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4
Node Name	https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4
Method	GET
Parameter	
Attack	
Evidence	
Show/hide Request and Resp	

on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
30
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
88
7
by
te
s.

Re
sp
on
se
Bo
dy

- size: 391,158 bytes.

Instances 1

Solution Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.

Reference
https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
https://owasp.org/www-community/Security_Headers
https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
https://caniuse.com/stricttransportsecurity
https://datatracker.ietf.org/doc/html/rfc6797

Tags
OWASP_2021_A05
OWASP_2017_A06
POLICY_QA_STD =
POLICY_PENTEST =
SYSTEMIC
CWE-319

CWE Id 319

WASC Id 15

Plugin Id 10035

Low **Timestamp Disclosure - Unix**

Description A timestamp was disclosed by the application/web server. - Unix

URL http://10.128.162.166/vulnerabilities/javascript/

Node Name http://10.128.162.166/vulnerabilities/javascript/

Method	GET
Parameter	
Attack	
Evidence	1473231341
Show/hide Request and Response	
Request Header-size: 463 bytes.	
Reques	

t Body-size: 0 bytes.

Response Header-size: 363 bytes.

Response Body-size: 8,381 bytes.

URL http://10.128.162.166/vulnerabilities/javascript/

Node Name http://10.128.162.166/vulnerabilities/javascript/

Method GET

Parameter

Attack

Evidence 1732584193

Show/hide Request and Response

Request Header-size: 463 bytes.

Request Body-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
8,
38
1
by
te
s.

URL http://10.128.162.166/vulnerabilities/javascript/

No
de
Na
me http://10.128.162.166/vulnerabilities/javascript/

Me
th
od GET

Pa
ra
me
te

r

Attack

Evidence 1732584194

Show/hide Request and Response

Request Header-size: 463 bytes.

Request Body-size: 0 byte

s.

Response Header-size: 363 bytes.

Response Body-size: 8,381 bytes.

URL http://10.128.162.166/vulnerabilities/javascript/

Node Name http://10.128.162.166/vulnerabilities/javascript/

Method GET

Parameter

Atta

ck

Evidence 1770035416

Show/hide Request and Response

Request Header-size: 463 bytes.

Request Body-size: 0 bytes.

Resp

onse Header-size: 363 bytes.

Response Body-size: 8,381 bytes.

URL http://10.128.162.166/vulnerabilities/javascript/

Node Name http://10.128.162.166/vulnerabilities/javascript/

Method GET

Parameter

Attack

Evid 1958414417

en
ce

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
46
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er

-size: 363 bytes.

ResponseBody-size: 8,381 bytes.

URL	https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4
NodeName	https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4
Method	GET
Parameter	
Attack	
Evidence	1703946492

Show/hide Request and Response

Request Header-size: 303 bytes.

Request Body-size: 0 bytes.

Response Header-size

:887bytes.

ResponseBody-size:391,158bytes.

URL https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

NodeName https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Method GET

Parameter

Attack

Evidence 1775952008

Show/

hide Request and Response

Request Header-size: 303 bytes.

Request Body-size: 0 bytes.

Response Header-size: 887 by

tes.

Response Body - size: 391,158 bytes.

URL https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Node Name https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Method GET

Parameter

Attack

Evidence 1827377968

Show/hideRequ

est
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
30
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
88
7
by
te
s.

Response Body - size: 391,158 bytes.

URL https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Node Name https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Method GET

Parameter

Attack

Evidence 1967152771

Show/hide Request an

d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
30
3
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
88
7
by
te
s.

Re
sp
on

se
Bo
dy
-
si
ze
:
39
1,
15
8
by
te
s.

Instances	Systemic
Solution	Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.
Reference	https://cwe.mitre.org/data/definitions/200.html
Tags	OWASP_2021_A01 OWASP_2017_A03 POLICY_PENTEST = CWE-497 SYSTEMIC
CWE Id	497
WASC Id	13
Plugin Id	10096

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/

Method GET

Parameter x-content-type-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 229 bytes.

Reques

t Body-size: 0 bytes.

Response Header-size: 308 bytes.

Response Body-size: 1,523 bytes.

URL http://10.128.162.166/dvwa/css/login.css

Node Name http://10.128.162.166/dvwa/css/login.css

Method GET

Parameter x-content-type-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 356 bytes.

Request Body-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
25
0
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
84
2
by
te
s.

URL http://10.128.162.166/login.php

No
de
Na
me http://10.128.162.166/login.php

Me
th
od GET

Parameter x-content-type-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 338 bytes.

Request Body-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
30
8
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
52
3
by
te
s.

URL http://10.128.162.166/robots.txt

No
de
Na
me http://10.128.162.166/robots.txt

Me
th
od GET

Pa
ra
me
te x-content-type-options

r

Attack

Evidence

Show/hideRequestandResponse

RequestHeader-size:239bytes.

RequestBody-size:0byte

s.

Response Header-size: 227 bytes.

Response Body-size: 26 bytes.

URL http://10.128.162.166/security.php

Node Name http://10.128.162.166/security.php

Method GET

Parameter x-content-type-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 440 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 364 bytes.

Response Body-size: 5,389 bytes.

URL https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Node Name https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Method GET

Parameter x-content-type-options

Attack

Evidence

Show/hide Request and Response

Request Header-size: 303 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 887 bytes.

Response Body-size: 391,158 bytes.

Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
Tags	CWE-693 OWASP_2021_A05 OWASP_2017_A06 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC
CWE Id	693
WASC Id	15

Plugin Id	10021

Informational	**Authentication Request Identified**
Description	The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified.
URL	http://10.128.162.166/vulnerabilities/brute/
Node Name	http://10.128.162.166/vulnerabilities/brute/ ()(Login,password,user_token,username)
Method	POST
Parameter	Login
Attack	
Evidence	password
Show/hide Request and Response	

se

Request Header-size: 443 bytes.

Request Body-size: 81 bytes.

Response Header-size: 335 bytes.

Response Body-

size: 0 bytes.

URL http://10.128.162.166/vulnerabilities/captcha/

Node Name http://10.128.162.166/vulnerabilities/captcha/ ()(Change,password_conf,password_current,password_new,step,user_token)

Method POST

Parameter user_token

Attack

Evidence password_conf

Show/hide Request and Response

Request He

ad
er
-
si
ze
:
44
8
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
12
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
33
5
by
te
s.

Response Body - size: 0 bytes.	
URL	http://10.128.162.166/vulnerabilities/brute/?username=admin&password=test123&Login=Login
Node Name	http://10.128.162.166/vulnerabilities/brute/ (Login,password,username)
Method	GET
Parameter	Login
Attack	
Evidence	password
Show/hide Request and Resp	

on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
50
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
4
by
te
s.

Re
sp
on
se
Bo
dy

-size: 4,375 bytes.

URL	http://10.128.162.166/login.php
Node Name	http://10.128.162.166/login.php () (Login,password,user_token,username)
Method	POST
Parameter	Login
Attack	
Evidence	password
Show/hide Request and Response	

Request Header-size: 417 bytes.

Request Body-size: 81 bytes.

Response Header-size: 329 bytes.

Response Body-size

: 0 bytes.	
Instances	4
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/
Tags	
CWE Id	
WASC Id	
Plugin Id	10111

Informational	**Information Disclosure - Sensitive Information in URL**
Description	The request appeared to contain sensitive information leaked in the URL. This can violate PCI and most organizational compliance policies. You can configure the list of strings for this check to add or remove values specific to your environment.
URL	http://10.128.162.166/vulnerabilities/brute/?username=admin&password=test123&Login=Login
Node Name	http://10.128.162.166/vulnerabilities/brute/ (Login,password,username)
Method	GET
Parameter	password

Attack

Evidence password

Show/hide Request and Response

Request Header-size: 504 bytes.

Request Body-size: 0 bytes.

Response Header-size: 364 bytes.

Response Body-size: 4,375 bytes.

URL http://10.128.162.166/vulnerabilities/brute/?username=admin&password=test123&Login=Login

Node Name http://10.128.162.166/vulnerabilities/brute/ (Login,password,username)

Method GET

Parameter username

Attack

Evidence

username

Show/hide Request and Response

Request Header-size: 504 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 364 bytes.

Response Body-size: 4,375 bytes.

URL http://10.128.162.166/vulnerabilities/csrf/?Change=Change&password_conf=ZAP&password_current=ZAP&password_new=ZAP

Node Name http://10.128.162.166/vulnerabilities/csrf/(Change,password_conf,password_current,password_new)

Method GET

Parameter password_conf

Attack

Evidence

password_conf

Show/hide Request and Response

Request Header-size: 441 bytes.

Request Body-size: 0 bytes.

Response

Header-size: 335 bytes.	
Response Body-size: 0 bytes.	
URL	http://10.128.162.166/vulnerabilities/csrf/?Change=Change&password_conf=ZAP&password_current=ZAP&password_new=ZAP
Node Name	http://10.128.162.166/vulnerabilities/csrf/(Change,password_conf,password_current,password_new)
Method	GET
Parameter	password_current
Attack	
Evidence	password_current

Show/hide Request and Response

Request Header-size: 441 bytes.

Request Body-size: 0 bytes.

Response Header-size

: 335 bytes.

ResponseBody-size: 0 bytes.

URL http://10.128.162.166/vulnerabilities/csrf/?Change=Change&password_conf=ZAP&password_current=ZAP&password_new=ZAP

NodeName http://10.128.162.166/vulnerabilities/csrf/(Change,password_conf,password_current,password_new)

Method GET

Parameter password_new

Attack

Evidence password_new

Show/hideRe

quest and Response

Request Header-size: 441 bytes.

Request Body-size: 0 bytes.

Response Header-size: 335 bytes.

Response Body - size: 0 bytes.

Instances	5
Solution	Do not pass sensitive information in URIs.
Reference	
Tags	CWE-598 OWASP_2021_A01 POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC OWASP_2017_A03 POLICY_DEV_STD =
CWE Id	598
WASC Id	13
Plugin Id	10024

Informational	**Information Disclosure - Suspicious Comments**
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://10.128.162.166/vulnerabilities/javascript/
Node Name	http://10.128.162.166/vulnerabilities/javascript/

Method GET

Parameter

Attack

Evidence from

Show/hide Request and Response

Request Header-size: 463 bytes.

Reques

t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
3
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
8,
38
1
by
te
s.

URL http://10.128.162.166/setup.php

No
de
Na
me http://10.128.162.166/setup.php

Me
th
od GET

Parameter

Attack

Evidence db

Show/hide Request and Response

Request Header-size: 338 bytes.

Request Body-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
30
8
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
5,
43
9
by
te
s.

Instances	2
Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
Tags	OWASP_2021_A01 WSTG-v42-INFO-05 OWASP_2017_A03 POLICY_PENTEST = CWE-615
CWE Id	615

WASC Id	13
Plugin Id	10027

Informational	**Modern Web Application**
Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://10.128.162.166/phpinfo.php
Node Name	http://10.128.162.166/phpinfo.php
Method	GET
Parameter	
Attack	
Evidence	<a name="module_apache2handler">apache2handler</a>
Show/hideRequestandResponse	

se

Request Header-size: 340 bytes.

Request Body-size: 0 bytes.

Response Header-size: 332 bytes.

Response Body-

size: 76,823 bytes.

Instances 1

Solution This is an informational alert and so no changes are required.

Reference

Tags POLICY_QA_STD = POLICY_PENTEST = SYSTEMIC POLICY_DEV_STD =

CWE Id

WASC Id

Plugin Id 10109

Informational **Retrieved from Cache**

Description The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.

URL https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Node Name https://firefox-settings-attachments.cdn.mozilla.net/bundles/startup.json.mozlz4

Method GET

Parameter

Attack

Evidence HIT

Show/hideRequestandResponse

RequestHeader-size:303bytes.

RequestBody-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
88
7
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
39
1,
15
8
by
te
s.

Instances 1

Solution	Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user: Cache-Control: no-cache, no-store, must-revalidate, private Pragma: no-cache Expires: 0 This configuration directs both HTTP 1.0 and HTTP 1.1 compliant caching servers to not store the response, and to not retrieve the response (without validation) from the cache, in response to a similar request.
Reference	https://datatracker.ietf.org/doc/html/rfc7234 https://datatracker.ietf.org/doc/html/rfc7231 https://www.rfc-editor.org/rfc/rfc9110.html
Tags	WSTG-v42-ATHN-06 CWE-525 POLICY_PENTEST = SYSTEMIC
CWE Id	525
WASC Id	
Plugin Id	10050

Informational	**Session Management Response Identified**
Description	The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET

Parameter security

Attack

Evidence security

Show/hideRequestandResponse

RequestHeader-size:229bytes.

RequestBody-si

ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
49
8
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
0
by
te
s.

URL http://10.128.162.166/

No
de
Na
me http://10.128.162.166/

Me
th
od GET

Pa
ra
me
te
r PHPSESSID

Attack

Evidence PHPSESSID

Show/hide Request and Response

Request Header-size: 275 bytes.

Request Body-size: 0 bytes.

Response Header-size: 419 bytes.

Response Body-size: 6,728 bytes.

Instances	2
Solution	This is an informational alert rather than a vulnerability and so there is nothing to fix.
Reference	https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/
Tags	
CWE Id	
WASC Id	
Plugin Id	10112

Informational **User Agent Fuzzer**

Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://10.128.162.166/
Node Name	http://10.128.162.166/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Show/hide Request and Response	
Request Head	

er
-
si
ze
:
16
8
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
47
7
by
te
s.

Response Body - size: 1,523 bytes.

URL http://10.128.162.166/

Node Name http://10.128.162.166/

Method GET

Parameter Header User-Agent

Attack Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)

Evidence

Show/hide Request and Re

sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
16
8
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
47
7
by
te
s.

Re
sp
on
se
Bo

dy
-
si
ze
:
1,
52
3
by
te
s.

URL http://10.128.162.166/

No
de
Na
me http://10.128.162.166/

Me
th
od GET

Pa
ra
me
te
r Header User-Agent

At
ta
ck Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)

Ev
id
en
ce

Sh
ow
/
hi
de
Re
qu
es
t
an
d
Re
sp
on
se

Request Header-size: 168 bytes.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size

:
1,
523
bytes.

URL http://10.128.162.166/

No de Na me http://10.128.162.166/

Me th od GET

Pa ra me te r Header User-Agent

At ta ck Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko

Ev id en ce

Sh ow / hi de Re qu es t an d Re sp on se

Re qu es t He

ad
er
-
si
ze
:
18
0
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
47
7
by
te
s.

Re
sp
on
se
Bo
dy
-
si
ze
:
1,
52
3
by
te

s.

URL http://10.128.162.166/

Node Name http://10.128.162.166/

Method GET

Parameter Header User-Agent

Attack Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0

Evidence

Show/hide Request and Response

Request Header-size:

246 bytes.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size: 1,523 bytes.

URL http://10.130.152.1/

Node Name	http://10.130.152.1/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Show/hide Request and Response	
Request Header-size: 164 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size: 1,523 bytes.

URL http://10.130.152.1/

Node Name	http://10.130.152.1/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Show/hide Request and Response	
Request Header-size: 164 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size: 1,523 bytes.

URL http://10.130.152.1/

Node Name	http://10.130.152.1/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Show/hide Request and Response	
Request Header-size: 164 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size: 1,523 bytes.

URL http://10.130.152.1/

Node Name	http://10.130.152.1/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/5.0 (Windows NT 10.0; Trident/7.0; rv:11.0) like Gecko
Evidence	
Show/hide Request and Response	
Request Header-size: 176 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size: 1,523 bytes.

URL http://10.130.152.1/

Node Name	http://10.130.152.1/
Method	GET
Parameter	Header User-Agent
Attack	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/75.0.3739.0 Safari/537.36 Edg/75.0.109.0
Evidence	
Show/hide Request and Response	
Request Header-size: 242 byte	

s.

Request Body-size: 0 bytes.

Response Header-size: 477 bytes.

Response Body-size: 1,523 bytes.

Instances Systemic

Solution

Reference https://owasp.org/wstg

Tags	CUSTOM_PAYLOADS = POLICY_PENTEST = SYSTEMIC
CWE Id	
WASC Id	
Plugin Id	10104

Informational	**User Controllable HTML Element Attribute (Potential XSS)**
Description	This check looks at user-supplied input in query string parameters and POST data to identify where certain HTML attribute values might be controlled. This provides hot-spot detection for XSS (cross-site scripting) that will require further review by a security analyst to determine exploitability.
URL	http://10.128.162.166/vulnerabilities/brute/?username=admin&password=test123&Login=Login
Node Name	http://10.128.162.166/vulnerabilities/brute/ (Login,password,username)
Method	GET
Parameter	Login
Attack	
Evidence	
Show/hi	

de
Re
qu
es
t
an
d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
50
4
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
0
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
4
by
te

s.

Response Body - size: 4,375 bytes.

URL http://10.128.162.166/vulnerabilities/xss_s/

Node Name http://10.128.162.166/vulnerabilities/xss_s/ ()(btnSign,mtxMessage,txtName)

Method POST

Parameter btnSign

Attack

Evidence

Show/hide Request an

d
Re
sp
on
se

Re
qu
es
t
He
ad
er
-
si
ze
:
56
1
by
te
s.

Re
qu
es
t
Bo
dy
-
si
ze
:
59
by
te
s.

Re
sp
on
se
He
ad
er
-
si
ze
:
36
4
by
te
s.

Re
sp
on

se
Bo
dy
-
si
ze
:
5,
06
9
by
te
s.

Instances	2
Solution	Validate all input and sanitize output it before writing to any HTML attributes.
Reference	https://cheatsheetseries.owasp.org/cheatsheets/Input_Validation_Cheat_Sheet.html
Tags	OWASP_2017_A01 OWASP_2021_A03 CWE-20 POLICY_PENTEST =
CWE Id	20
WASC Id	20
Plugin Id	10031

Report by ZAP